



ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA

Universidad de las Fuerzas Armadas ESPE

Departamento de Ciencias de la Computación

Ingeniería de Software

SentinelML-ABAC: Sistema de Control de Acceso Industrial con Inferencia Resiliente a Ataques de Evasión

**Proyecto: Idea de una Solución de
Seguridad Novedosa**

Integrantes:

Caetano Flores

Jordan Guamán

Mesías Mariscal

Anthony Morales

Leonardo Narváez

Denise Rea

Docente: Sang Guun Yoo, PhD

Sangolquí, Ecuador

Julio de 2026

Índice

1. Introducción y Planteamiento del Problema	3
2. Criterios de Selección y Pertinencia de la Solución	4
3. Marco Teórico y Estado del Arte	5
3.1. Fundamentos, Malware y Vectores de Red (Unidad 1)	5
3.2. Criptografía y Control de Acceso (Unidad 2)	5
3.3. Protocolos Criptográficos, Seguridad Perimetral y SGSI (Unidad 3)	5
3.4. Seguridad en Inteligencia Artificial y MLSecOps (Parcial III)	6
4. Descripción de la Solución Propuesta	6
5. Detalle Técnico del Sistema	7
5.1. Modelo de Amenazas (STRIDE / MITRE ATLAS)	7
5.2. Mitigación de Evasión (Modelo Matemático FGSM)	8
5.3. Detección de Data Drift (Distancia de Wasserstein)	8
5.4. Algoritmo del Guardrail del Control de Acceso	9
6. Consideraciones de Implementación y Gobernanza (ISO/IEC 27001)	10
7. Conclusiones	11

1. Introducción y Planteamiento del Problema

La transformación digital en entornos de automatización industrial y de infraestructura crítica (como plantas de energía, refinerías y sistemas de distribución de agua) ha acelerado la convergencia entre la tecnología de operaciones (OT) y la tecnología de la información (IT). Los sistemas tradicionales SCADA (Supervisory Control and Data Acquisition) y los sensores del Internet de las Cosas Industrial (IIoT) operan bajo redes que históricamente dependían del aislamiento físico como su principal defensa. Sin embargo, con la integración de APIs, conectividad IP y la toma de decisiones asistida por modelos de Inteligencia Artificial (IA), este aislamiento ha desaparecido, exponiendo la infraestructura a vectores de ataque altamente sofisticados.

En este nuevo paradigma, la toma de decisiones sobre el control de acceso a recursos físicos e informáticos críticos no puede limitarse a políticas estáticas tradicionales. El volumen dinámico del tráfico y el comportamiento mutante de los sensores exigen un enfoque de control de acceso adaptativo basado en atributos (ABAC). Sin embargo, los motores de IA y Machine Learning (ML) incorporados para estimar los atributos de riesgo y clasificar el comportamiento del sistema son intrínsecamente vulnerables.

Los atacantes de nivel Máster o APTs (Amenazas Persistentes Avanzadas) han desarrollado técnicas de evasión matemática o ejemplos adversarios (Adversarial Examples), consistentes en perturbar levemente las señales de telemetría de los sensores de manera que, siendo imperceptibles para un operador humano, logren que el clasificador probabilístico del sistema identifique tráfico malicioso o destructivo como legítimo. Esto permitiría a un intruso forzar la apertura de válvulas de presión, sabotear turbinas o exfiltrar datos, saltándose los mecanismos de autorización y eludiendo las alertas del IDS.

El problema central radica en diseñar una arquitectura de control de acceso industrial que implemente políticas ABAC robustas, pero cuyos componentes de clasificación de seguridad mediante modelos de aprendizaje automático cuenten con un escudo proactivo contra ataques de envenenamiento de datos (Data Poisoning) y de evasión (como FGSM). Asimismo, la arquitectura debe garantizar la integridad física de los pesos del modelo, operar con latencias críticas y estar enmarcada bajo un sistema de gestión estructurado (SGSI). En respuesta a este desafío, este informe detalla la conceptualización y desarrollo de la propuesta, la cual se alinea con el requerimiento académico de formular una **Idea de una Solución de Seguridad Novedosa** para mitigar riesgos en infraestructuras críticas.

2. Criterios de Selección y Pertinencia de la Solución

La solución planteada, denominada **SentinelML-ABAC**, ha sido seleccionada específicamente para mitigar las debilidades del ecosistema SCADA moderno mediante la combinación integrada de conceptos de control de acceso formal, criptografía híbrida e ingeniería de MLSecOps. Los criterios que justifican su selección frente a esquemas tradicionales son:

1. **Flexibilidad y Contextualización Dinámica (ABAC vs. RBAC):** A diferencia del control de acceso basado en roles (RBAC) que es rígido y no contempla condiciones del entorno, ABAC permite incorporar atributos dinámicos temporales y técnicos (p.ej., la dirección IP del sensor, el nivel de seguridad de la red de origen, la tasa de anomalías en el canal físico y la coherencia del historial de telemetría) regulando de manera granular los permisos de lectura y escritura en los actuadores de planta.
2. **Garantía Estricta de la Integridad (Modelo Biba):** Dado que un flujo de datos erróneo o manipulado en un sensor industrial podría provocar daños catastróficos a nivel físico (Safety), se selecciona la política del modelo de integridad de Biba (*no-read-down, no-write-up*). Esto garantiza que procesos de baja confianza en la red corporativa o dispositivos comprometidos de la periferia no puedan escribir o alterar parámetros de control del kernel central o bases de datos de alta integridad.
3. **Protección Criptográfica del Pipeline de ML:** Los modelos de IA suelen guardarse en formatos de serialización vulnerables (como Pickles de Python) que permiten la ejecución remota de código (RCE) al ser montados. La solución introduce el formato binario plano Safetensors y la firma criptográfica obligatoria mediante hashes SHA-256 en la PKI corporativa antes del arranque del servicio de inferencia, garantizando la confidencialidad y la inmutabilidad de los pesos del clasificador.
4. **Monitoreo Activo de Desviación (Data Drift):** A diferencia de los IDS estáticos basados en firmas que fallan ante malware de mutación polimórfica o ataques de día cero, **SentinelML-ABAC** integra el cálculo en tiempo real del Population Stability Index (*PSI*) y la Distancia de Wasserstein. Esto permite detectar de forma proactiva desalineaciones estadísticas en el tráfico antes de que el modelo degrade su precisión a niveles inseguros, permitiendo ejecutar rollbacks automáticos en menos de 5 segundos.

3. Marco Teórico y Estado del Arte

La arquitectura propuesta unifica las tres unidades fundamentales del programa de Ingeniería de Seguridad de Software y los avances en seguridad aplicados a sistemas de inteligencia artificial:

3.1. Fundamentos, Malware y Vectores de Red (Unidad 1)

La triada CIA es el fundamento para el resguardo de infraestructuras críticas. En redes industriales, la disponibilidad e integridad toman prioridad crítica sobre la confidencialidad para evitar fallos de seguridad física (safety) [1]. Los actores de amenazas sofisticados, como APTs y el crimen organizado, despliegan payloads maliciosos que evaden firewalls perimetrales mediante el uso de botnets de IoT (como Mirai [2]) y técnicas de ocultamiento de kernel (rootkits). Los ataques comunes de red como el envenenamiento ARP (ARP poisoning) y la suplantación de IP (IP spoofing) son utilizados para interceptar comunicaciones (eavesdropping) o inyectar comandos fraudulentos mediante Man-in-the-Middle (MITM) y ataques de reproducción (replay).

3.2. Criptografía y Control de Acceso (Unidad 2)

La criptografía híbrida combina el cifrado simétrico (AES-256) para el canal de datos de alta velocidad con el cifrado asimétrico (ECC) para la distribución segura de claves. La autenticación robusta requiere al menos un esquema multifactor (MFA). El control de acceso discrecional (DAC) basado en matrices y listas de control de acceso (ACL) resulta ineficiente e inseguro en redes de miles de nodos, requiriendo el salto a modelos mandatorios (MAC) y basados en atributos (ABAC). A nivel formal, el modelo Bell-LaPadula previene la fuga de secretos de alta clasificación, mientras que el modelo Biba se enfoca en asegurar la integridad evitando que datos contaminados corrompan a capas superiores.

3.3. Protocolos Criptográficos, Seguridad Perimetral y SGSI (Unidad 3)

Los protocolos de autenticación centralizada como Kerberos solucionan el problema del almacenamiento descentralizado de credenciales mediante el uso de Tickets cifrados de corta duración emitidos por un Centro de Distribución de Claves (KDC). Kerberos extiende conceptos del protocolo Needham-Schroeder utilizando marcas de tiempo (timestamps) y nonces para desarmar ataques de reproducción antiguos. El diseño global se rige por un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma internacional ISO/IEC 27001 [3], estructurado bajo la metodología de mejora continua PDCA (Plan, Do, Check, Act).

3.4. Seguridad en Inteligencia Artificial y MLSecOps (Parcial III)

Los modelos probabilísticos de aprendizaje automático introducen vulnerabilidades no cubiertas por parches de software tradicionales. El ataque de envenenamiento de datos (Data Poisoning) manipula el dataset durante el entrenamiento para implantar puertas traseras en el modelo. Durante la inferencia, los ejemplos adversarios (Adversarial Examples) perturban la entrada empleando algoritmos de optimización matemática de gradiente (como el método FGSM) para causar clasificaciones erróneas [4]. Para asegurar la resiliencia en entornos de producción, el ciclo de MLSecOps introduce el escaneo estático de modelos, guardrails semánticos y la medición continua del Data Drift para calibrar la estabilidad operacional.

4. Descripción de la Solución Propuesta

La arquitectura propuesta concreta la **Idea de una Solución de Seguridad Novedosa** denominada **SentinelML-ABAC**, la cual es una pasarela de seguridad inteligente de control de acceso perimetral. Actúa como un intermediario entre la capa de sensores IIoT y los PLC/actuadores que ejecutan comandos de control de planta.

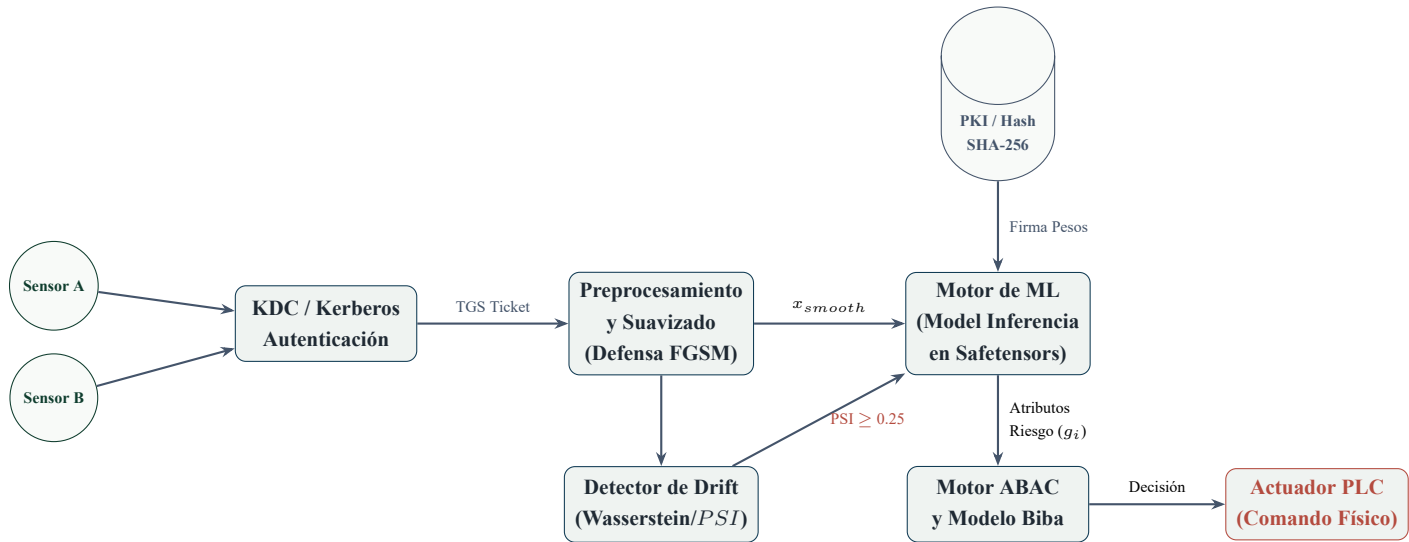


Figura 1: Diagrama de arquitectura del flujo de datos en el sistema SentinelML-ABAC.

La novedad de la solución radica en su ****enfoque de defensa holístico por diseño****, donde los datos recibidos de la red pasan por tres compuertas lógicas antes de que se autorice la ejecución de cualquier acción física: 1. ****Filtro Criptográfico de Identidad y Freshness****: Los dispositivos deben autenticarse usando Kerberos y ECC. Se descartan mensajes duplicados mediante el análisis de nonces y timestamps. 2. ****Escudo Físico de Evasión (Suavizado de Datos)****: Para neutralizar el

ruido adversario imperceptible del método FGSM, el tráfico pasa por un preprocesador matemático de suavizado espectral que dispersa la estructura del ruido de gradiente. 3. ****Inferencia Resiliente y ABAC con Biba****: Un modelo local estima el nivel de riesgo del canal y la coherencia del comando. Los pesos del modelo son validados criptográficamente en memoria utilizando Safetensors. Si se aprueba el nivel de integridad Biba y las reglas ABAC, el comando se envía al actuador; en caso contrario, se desactiva la clave del dispositivo sospechoso y se conmuta en caliente a un modelo determinista estático de emergencia.

A diferencia de los IDS de red clásicos que informan del ataque posterior a la infección, ****SentinelML-ABAC**** intercepta la inferencia en tiempo real en la capa de autorización del control de acceso, actuando de forma preventiva.

5. Detalle Técnico del Sistema

5.1. Modelo de Amenazas (STRIDE / MITRE ATLAS)

El diseño del sistema responde a una modelación sistemática de amenazas industriales e inteligencia artificial, detallada en la Tabla 1.

Categoría STRIDE	Amenaza Técnica Específica	Técnica MITRE ATLAS	Mitigación SentinelML-ABAC
Spoofing	Suplantación de identidad del sensor en la red de telemetría.	AML.T0008: <i>Impersonation</i>	Autenticación mutua con ECC y tickets cifrados en Kerberos.
Tampering	Modificación de la telemetría mediante ejemplos adversarios (FGSM).	AML.T0015: <i>Evade ML Model</i>	Suavizado de datos pre-inferencia y monitoreo de Data Drift.
Repudiation	Negación de envío de parámetros de control erróneos por un sensor.	AML.T0020: <i>Exfiltrar pesos</i>	Firma digital de mensajes basada en claves privadas asimétricas en la RA de la PKI.
Information Leak	Exfiltración de pesos y arquitectura del modelo de clasificación.	AML.T0012: <i>Model Extraction</i>	Rate limiting y perturbación de confianzas en los outputs.
Denial of Service	Inundación de la pasarela de control mediante botnets industriales.	AML.T0029: <i>Denial of Service</i>	Rate limiting a nivel de gateway IP y filtrado de IP Spoofing.
Elevation of Priv	Inyección RCE mediante deserialización de modelos comprometidos.	AML.T0010: <i>Poison Training Data</i>	Uso estricto de Safetensors y verificación SHA-256 de firmas de modelos.

Cuadro 1: Modelado de amenazas combinando el estándar STRIDE y la matriz MITRE ATLAS.

5.2. Mitigación de Evasión (Modelo Matemático FGSM)

Un atacante de nivel Elite genera telemetría adversaria aplicando el método rápido de signo de gradiente (FGSM). La entrada adversaria x_{adv} se modela como:

$$x_{adv} = x + \epsilon \cdot \text{sign}(\nabla_x L(\theta, x, y)) \quad (1)$$

Donde x es la señal legítima, ϵ es el límite del presupuesto de ruido del atacante, θ representa los pesos del clasificador y $L(\theta, x, y)$ es la función de pérdida del modelo. El operador de signo extrae la dirección de gradiente que maximiza el error de clasificación.

SentinelML-ABAC contrarresta esto implementando un preprocesamiento de suavizado de entrada, aplicando un filtro de media móvil y una ligera inyección de ruido Gaussiano controlado $\eta \sim \mathcal{N}(0, \sigma^2)$ antes de la fase de inferencia:

$$x_{smooth} = \text{Filter}(x_{adv}) + \eta \quad (2)$$

Este proceso desacopla la perturbación exacta del vector de gradiente $\nabla_x L$, destruyendo la efectividad del ataque evasivo y estabilizando el comportamiento probabilístico del clasificador.

5.3. Detección de Data Drift (Distancia de Wasserstein)

Para identificar ataques sofisticados de deriva lenta o envenenamiento en caliente, el sistema calcula de forma síncrona en una ventana temporal de inferencias de tamaño N la Distancia de Wasserstein de primer orden (Earth Mover's Distance) entre la distribución de entrenamiento P_r y la distribución observada en producción P_g :

$$W_1(P_r, P_g) = \inf_{\gamma \in \Pi(P_r, P_g)} \mathbb{E}_{(x,y) \sim \gamma} [\|x - y\|] \quad (3)$$

Junto a la distancia de Wasserstein, se calcula el Population Stability Index (PSI) para las variables de entrada:

$$PSI = \sum_{i=1}^k (P_{g,i} - P_{r,i}) \cdot \ln \left(\frac{P_{g,i}}{P_{r,i}} \right) \quad (4)$$

El sistema de telemetría activa alarmas y conmuta las decisiones del control de acceso de acuerdo con los siguientes umbrales operativos:

- $PSI < 0,10$: Operación normal del modelo inteligente.
- $0,10 \leq PSI < 0,25$: Desviación moderada; se envía una alerta en frío al SGSI y se programa un re-entrenamiento del modelo en la fase de CI/CD.

- $PSI \geq 0,25$: Desviación crítica (posible ataque de envenenamiento o evasión activa). Se ejecuta un ****rollback en caliente en menos de 5 segundos****, desviando el tráfico de inferencia al modelo base robusto determinista y suspendiendo temporalmente la validación del sensor comprometido.

5.4. Algoritmo del Guardrail del Control de Acceso

El flujo lógico del control de acceso integrado se presenta en el siguiente pseudocódigo:

Listing 1: Pseudocódigo del motor de autorización en la pasarela SentinelML-ABAC.

```

1 def authorize_sensor_request(sensor_id, request_data, security_ticket):
2     # 1. Validar ticket de autenticacion Kerberos
3     if not verify_kerberos_ticket(security_ticket):
4         log_security_event(sensor_id, "AUTH_FAILURE", "Severity: Critical")
5         return ACCESS_DENIED
6
7     # 2. Comprobar inmutabilidad y hash del modelo de ML antes de usar
8     current_model_hash = get_file_sha256("/models/classifier.safetensors")
9     if current_model_hash != EXPECTED_MODEL_SHA256:
10        log_security_event("SYSTEM", "MODEL_INTEGRITY_VIOLATION", "Severity: Emergency")
11        trigger_system_lockdown()
12        return ACCESS_DENIED
13
14    # 3. Aplicar suavizado a los datos de telemetria
15    smoothed_data = apply_gaussian_smoothing(request_data)
16
17    # 4. Calcular deriva estadistica (Drift)
18    psi_metric = calculate_population_stability_index(smoothed_data)
19    if psi_metric >= 0.25:
20        log_security_event(sensor_id, "CRITICAL_DRIFT_DETECTED", f"PSI: {psi_metric}")
21        activate_hot_rollback_to_baseline()
22        # Conmutacion al modelo base determinista
23        risk_score = evaluate_baseline_rules(smoothed_data)
24    else:
25        # Inferencia con modelo probabilistico Safetensors
26        risk_score = ml_model_inference(smoothed_data)
27
28    # 5. Evaluacion de la politica ABAC bajo el Modelo Biba
29    # Sujeto: sensor_id, Objeto: actuador_id. Atributo: Integrity Level (IL)
30    sensor_il = get_attribute(sensor_id, "IntegrityLevel")
31    command_il = get_attribute(request_data, "RequiredIntegrity")
32
33    # Biba Star Rule: No Write Down (Un sujeto no puede escribir en un objeto de mayor integridad)
34    # Biba Simple Integrity: No Read Up (Un sujeto no puede leer un objeto de menor integridad)
35    if sensor_il < command_il:
36        log_security_event(sensor_id, "BIBA_INTEGRITY_VIOLATION", f"Sensor IL {sensor_il} <
          Command IL {command_il}")
37        return ACCESS_DENIED
38
39    # Validacion de reglas ABAC del entorno
40    if evaluate_abac_rules(sensor_id, risk_score, current_env_attributes()):

```

```
41     return ACCESS_APPROVED
42 else:
43     return ACCESS_DENIED
```

6. Consideraciones de Implementación y Gobernanza (ISO/IEC 27001)

La implementación operativa de **SentinelML-ABAC** no se limita al despliegue técnico; debe estructurarse bajo un marco formal de gobernanza alineado con la norma **ISO/IEC 27001**, integrando el ciclo continuo **PDCA** (Plan-Do-Check-Act):

- **Plan (Planificar):** Definición del alcance del SGSI enfocado en el pipeline de datos industriales y de inteligencia artificial. Identificación de los activos (pesos del modelo, datasets, código fuente). Modelado y valoración de riesgos utilizando la matriz combinada STRIDE/MITRE ATLAS. Establecimiento de la Política de Inferencia Confiable y Ciberseguridad de Modelos aprobada por la alta gerencia.
- **Do (Hacer):** Despliegue de los controles técnicos: formato Safetensors, sandboxing de inferencia en Docker, infraestructura de firmas SHA-256 en la PKI y algoritmos de suavizado. Implementación de programas de formación y concientización a operadores de red OT sobre ataques de inyección e ingeniería social.
- **Check (Verificar):** Monitoreo y medición periódica de los controles mediante el Population Stability Index (*PSI*) y logs de auditoría forense inmutables de inferencias. Ejecución de simulaciones periódicas de intrusión y ataques de evasión (Red Teaming de IA) para comprobar la latencia del rollback de emergencia.
- **Act (Actuar):** Ejecución de acciones correctivas basadas en incidentes detectados. Si un sensor industrial muestra un comportamiento atípico repetitivo, se inicia su aislamiento de red (cuarentena) y se ajusta la política ABAC del entorno para restringir dinámicamente sus permisos. Actualización de las directivas de seguridad según nuevas técnicas publicadas en MITRE ATLAS.

Para la correcta trazabilidad del SGSI, el sistema mantiene de manera inmutable cuatro niveles documentales: 1. **Políticas**: Directrices globales sobre la autorización de telemetría y uso ético de modelos de IA en la corporación. 2. **Procedimientos**: Flujos operacionales de respuesta ante incidentes (p.ej., procedimiento de restauración en caliente tras una degradación del clasificador). 3. **Instrucciones**: Guías paso a paso para la generación de firmas de hashes y compilación segura

de Safetensors por el equipo de DevOps. 4. ****Registros****: Evidencias objetivas y logs firmados digitalmente de cada acceso concedido y alertas de deriva emitidas por el detector.

7. Conclusiones

- El sistema **SentinelML-ABAC** ofrece una respuesta eficaz e innovadora a la vulnerabilidad latente de los clasificadores inteligentes en entornos industriales críticos, deteniendo en tiempo de inferencia ataques sofisticados de evasión (como FGSM) antes de comprometer la seguridad física de los activos de planta.
- La integración sistemática del ****modelo de integridad Biba**** con las políticas basadas en atributos (****ABAC****) proporciona una granularidad de seguridad multinivel y una robustez que supera a los esquemas tradicionales estáticos, cumpliendo a cabalidad con la triada de seguridad industrial.
- La mitigación técnica basada en firmas criptográficas de pesos SHA-256, formatos serializados seguros como **Safetensors** y monitoreo continuo mediante **Distancia de Wasserstein** asegura la confiabilidad del ciclo MLSecOps en producción, garantizando consistencia tipográfica y técnica bajo los marcos NIST AI RMF y MITRE ATLAS.
- Finalmente, la estructuración del diseño bajo el ciclo continuo ****PDCA** de la norma ISO/IEC 27001 ****** asegura la alineación corporativa del sistema con estándares globales de calidad, auditabilidad y gobernanza de la seguridad de la información.

Referencias

- [1] NIST. (2018). *Security and Privacy Controls for Information Systems and Organizations* (NIST Special Publication 800-53, Rev. 5).
- [2] Antonakakis, M., et al. (2017). Understanding the Mirai Botnet. *USENIX Security Symposium*.
- [3] ISO/IEC. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001:2022).
- [4] Goodfellow, I. J., Shlens, J., & Szegedy, C. (2014). Explaining and harnessing adversarial examples. *arXiv preprint arXiv:1412.6572*.
- [5] NIST. (2023). *Artificial Intelligence Risk Management Framework* (AI RMF 1.0).
- [6] MITRE. (2021). *Adversarial Threat Landscape for Artificial-Intelligence Systems (ATLAS)*.

[7] OWASP. (2023). *Top 10 for Large Language Model Applications*.